RBAC: asignación de rol, autorización y denegación trazable

Defensa de arquitectura · Primera evaluación parcial

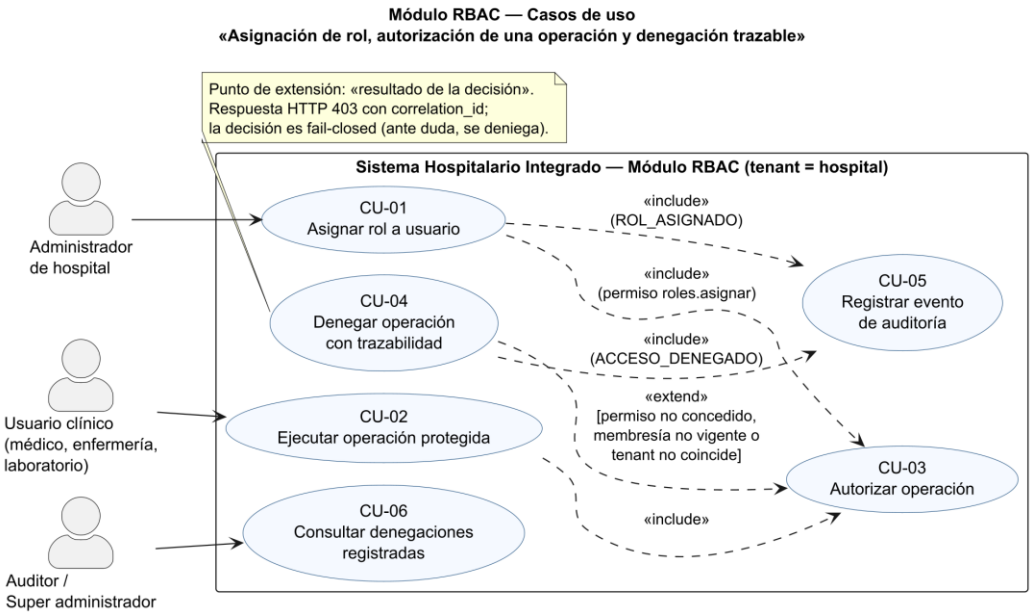
Boris Alexander Quiroa Orellana · Análisis de Sistemas II 2026

67
pruebas automáticas

0
fallas

17
decisiones con evidencia

Actores y proceso (UML)



A — **Administrador**
Asigna y revoca roles en su hospital

C — **Usuario clínico**
Ejecuta operaciones protegidas

Au — **Auditor**
Consulta denegaciones por correlation_id

Regla central: toda denegación deja evidencia y el 403 no revela el motivo

Requisitos y principio OCP

Requisitos clave (semana 2)

- **RF-05** autorizar cada operación por su permiso
- **RF-08/09** 403 con correlation_id + evento auditado
- **RNF-01** fail-closed: ante la duda, denegar
- **RNF-04** el 403 no revela rol ni motivo
- **RNF-05** agregar reglas sin modificar el decisor

Antes: una clase con if/elseif

Cada regla nueva obliga a modificar autorizar().

```
if (tenant ≠ token) …
elseif (sin membresía) …
elseif (sin permiso) …  // + otro elseif
```

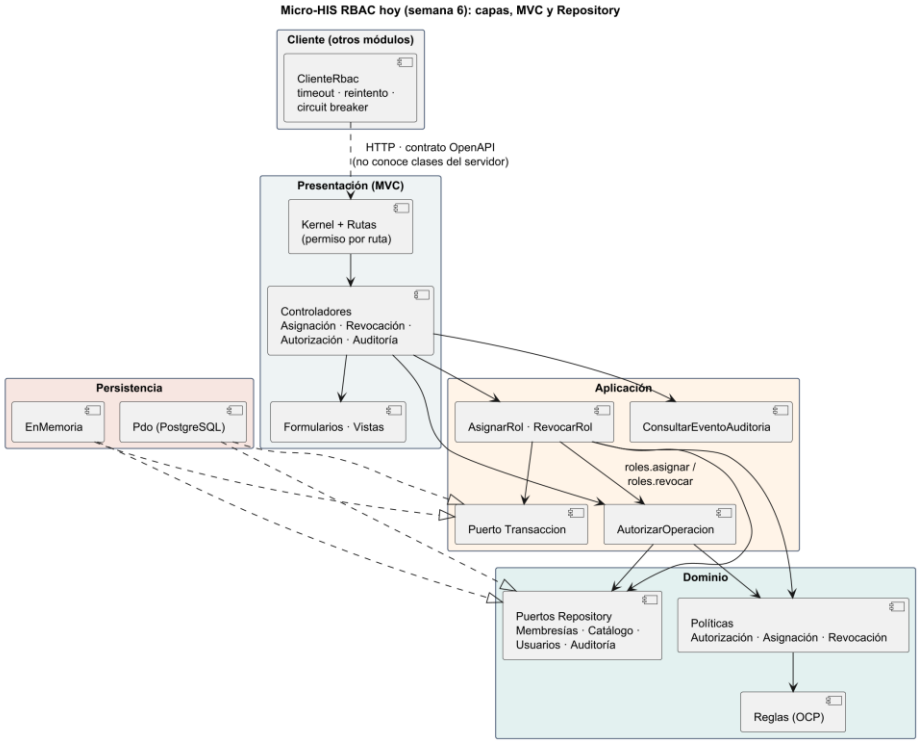
Después: reglas como extensiones

Regla nueva = clase nueva; el decisor no cambia.

```
foreach ($reglas as $regla)
  $motivo = $regla->evaluar($ctx);
```

Pruebas: DOM-02 y OCP-01..03

Capas y patrón Repository



Presentación MVC: controlador → caso de uso → vista

Aplicación Casos de uso y transacciones

Dominio Reglas y puertos; sin PDO ni HTTP

Persistencia PDO preparado e InMemory

Repository: 5 puertos en el Dominio × 2 adaptadores (PDO e InMemory), misma suite de contrato. **ARQ-01..08** fallan si se rompe la arquitectura.

Contrato API y frontera de servicio

Método	Ruta /api/v1	x-permiso
POST	/roles/asignaciones	roles.asignar
POST	/roles/revocaciones	roles.revocar
POST	/autorizaciones/decisiones	solo autenticación
GET	/auditoria/eventos/{id}	auditoria.consultar
POST	/prescripciones (demo)	prescripciones.crear

OpenAPI 3.1 validado (Redocly) y verificado contra el código: API-01..03.

0,006 ms

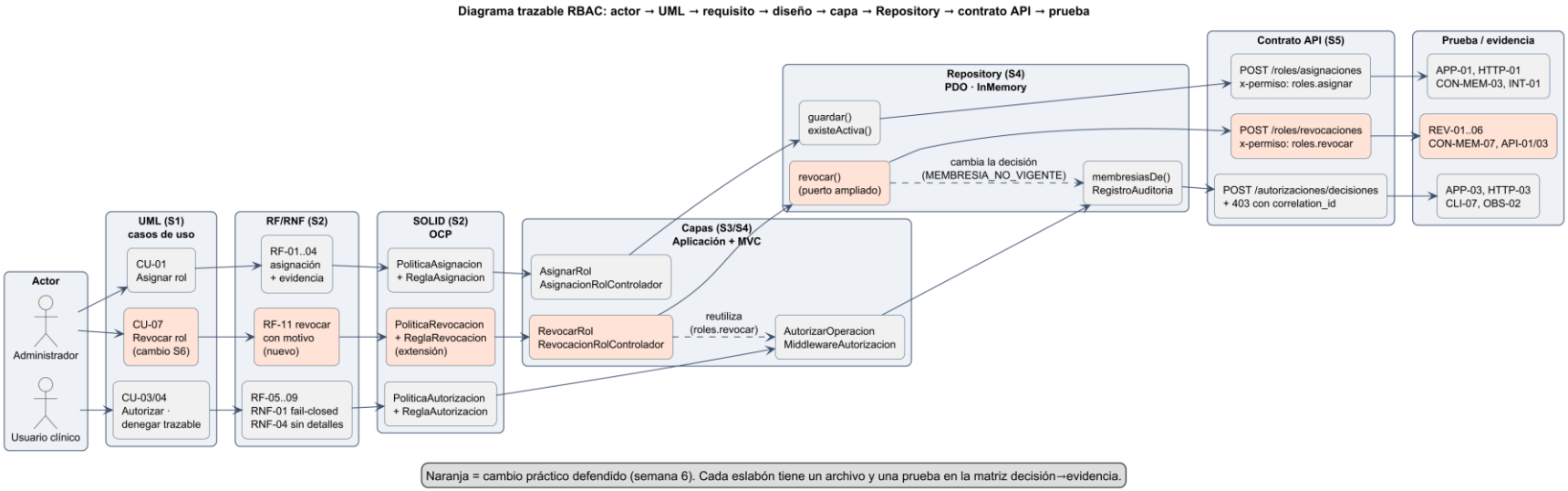
decisión dentro del proceso (p50)

33–62 ms

la misma decisión por red local (p50)

Decisión: monolito modular con frontera explícita. Extraer solo si se cumple algún criterio C1–C5 (hoy: ninguno).

Trazabilidad de punta a punta



Asignar: CU-01 → RF-01..04 → AsignarRol → guardar() → /roles/asignaciones → APP-01

Autorizar: CU-03/04 → RF-05..09 → AutorizarOperacion → membresiasDe() → PDP → APP-03

Revocar: CU-07 → RF-11..14 → RevocarRol → revocar() → /roles/revocaciones → REV-01..06

Cambio defendido: revocar un rol

1. **Admin revoca «enfermeria» con motivo**

   200 ROL_REVOCADO, auditado

2. **La enfermera registra signos vitales**

   403 + correlation_id

3. **El auditor consulta ese id**

   motivo MEMBRESIA_NO_VIGENTE

Pruebas primero: REV-01..06, CON-MEM-07, API-01/03

Impacto por capa

- Dominio: PoliticaRevocacion + 3 reglas (OCP)
- Aplicación: RevocarRol (reutiliza autorización)
- Repository: revocar() en PDO e InMemory
- MVC + contrato: ruta roles.revocar, v1.1.0
- Datos: permiso nuevo · evento ROL_REVOCADO

8 → 0

fallas: rojo → verde

0

líneas cambiadas en la autorización

Decisión → evidencia

Decisión	Evidencia
Denegación trazable, 403 sin motivo	APP-03, HTTP-03, CLI-07
OCP: reglas como extensiones	DOM-02, OCP-01..03, REV-04
Fail-closed en todas las capas	DOM-03, PER-08, CLI-03
4 capas + Repository PDO / InMemory	ARQ-01..08, CON-MEM-01..07
Contrato OpenAPI = código	API-01..03 + lint Redocly
No microservicio (medido)	bin/medir.php: 0,006 vs 33–62 ms
Cambio: revocar rol	REV-01..06, rojo → verde

Matriz completa (17 decisiones): docs/modulos/rbac/semana-06/matriz-decision-evidencia.md